Dentro da governança de riscos do BNDES, risco operacional é um conceito mais amplo que se refere à possibilidade de perdas decorrentes de falhas, inadequações ou eventos externos que afetem processos, pessoas, sistemas ou controles internos.

Definição de Risco à Segurança da Informação: potencial de violação da integridade, confidencialidade, disponibilidade ou autenticidade da informação de propriedade ou custodiada pelo Sistema BNDES em decorrência da exploração de uma ou mais vulnerabilidades de um ativo de informação ou de um conjunto de tais ativos, por parte de uma ou mais ameaças, com impacto negativo às Empresas do Sistema BNDES. Esta definição inclui o risco cibernético, que é o risco à segurança da informação que envolve ativo de tecnologia da informação.

O BNDES classifica como relevante todo serviço que manipula informação sensível ou que suporta seus sistemas principais - aqueles imprescindíveis para continuidade de processo crítico, ou seja, aquele definido como de recuperação urgente de acordo com a metodologia de gestão de continuidade de negócios.

Resumidamente, informação sensível para o BNDES são informações classificadas em grau de sigilo como “confidenciais”, dados pessoais sensíveis nos termos da LGPD, dados financeiros de clientes e de empregados, dados de projetos de clientes, estratégias de investimento, classificação de risco de clientes, informações que possam afetar a segurança do Sistema Financeiro Nacional e informações tratadas pelos sistemas principais.

São considerados sistemas principais de TI o portal institucional do BNDES (site do Banco na Internet) e aqueles cuja indisponibilidade causa impacto significativo nos processos fundamentais à atuação do Sistema BNDES, no mercado financeiro e de capitais, a saber: captação e gestão do passivo; realização de operações diretas, indiretas ou de renda variável; e cumprimento de obrigações ao Banco Central do Brasil (BACEN) e à Comissão de Valores Mobiliários (CVM).

Devem ser considerados sistemas principais para o BNDES os seguintes: Sistema de Contabilidade, Sistemas da Área Financeira que apoiam operações no SPB, Sistemas de Faturamento no SAP, Sistemas de Acompanhamento de Operações (N03), Sistema SRV, Sistema de Cobrança, Sistemas de controles de Títulos Públicos e Títulos de Valores Mobiliários, sistemas de controles de documentos (GED), além de recursos críticos da infraestrutura de TI, como o Active Diretory, Bancos de Dados Relacionais (SGBDs – Oracle e Microsoft SQL Server), Storage, NAS, Sistema SAP e módulos de HR e FI, elementos de controles de segurança cibernética (Firewall, VPN, Microsoft Defender), Serviços de correio eletrônico, Serviço Microsoft 365 e ativos de suporte à rede corporativa (roteadores, switches, WiFI etc).

Contratos que envolvem terceirização de mão de obra podem ser prestados de diferentes formas:

- contratos que preveem a alocação de mão-de-obra dedicada ao BNDES que atuam em postos de trabalho definidos no contrato;
- contratos de prestação de serviço que não especificam a quantidade de postos de trabalho, mas são prestados com a alocação de pessoas com acesso ao ambiente físico das instalações do BNDES ou com a alocação de pessoas com acesso remoto (por meio de VPN ou de canais de comunicação de dados/links dedicados) a sistemas do BNDES;
- São exemplos de contratos críticos para segurança cibernética que envolvem terceirização: contratos de fábrica de software com acesso remoto; contratos de suporte a sistemas de TI (SAP); contratos de suporte de rede (gestão de elementos da rede corporativa para configuração de switches, roteadores, firewall); CSOC para monitoramento e tratamento de incidentes de segurança cibernética; Service Desk; serviços de impressão; gestão do CPD / sala cofre; desenvolvimento e suporte especializado SAP ect.

Podem ser considerados prestadores de serviço críticos para segurança da informação:

Categoria de serviço	Por que é crítico?

Cloud (IaaS, PaaS, SaaS)	Hospeda dados, sistemas e processos críticos; risco direto à soberania, continuidade e sigilo
Data Center / Colocation	Custódia física e lógica de ativos de TI
DRaaS / Backup / Storage	Última linha de defesa contra perda de dados e repositório de arquivos e de máquinas virtuais
Virtualização e Containers	Comprometimento afeta múltiplos sistemas
Plataformas de identidade (IAM, SSO)	Controle de acesso institucional
DNS, e-mail corporativo, AD como serviço	Infraestrutura essencial de confiança
Fábricas de software / sustentação de sistemas	Código vulnerável = porta de entrada
NOC / SOC / MSSP / CSOC	Visibilidade e resposta a incidentes
Gestão de servidores, redes, firewalls	Poder de interrupção e sabotagem
Service desk com acesso remoto	Alto risco de abuso de credenciais
Administração de banco de dados	Acesso a dados sensíveis
Pentest / Red Team	Conhecem suas vulnerabilidades
Gestão de vulnerabilidades	Sabem “onde atacar”
SOC terceirizado	Podem ocultar incidentes
MSSP	Operam controles críticos
Fornecedores de SIEM, EDR, XDR	Controle da telemetria de segurança
CRM / SAC / contact center	Engenharia social
BI / Analytics	Exfiltração silenciosa
Fornecedores de software de terceiros	Backdoors, dependências
Sistemas de controles de APIs e integrações / gateway de API	Portas abertas permanentes
Plataformas low-code/no-code	Superfície invisível de ataque
Controle de acesso físico	Porta para sabotagem
CFTV / IoT predial	Pivotagem para rede e exposição de dados pessoais
Automação predial, como elevadores e controles de água, energia e ar-condicionado	Indisponibilidade sistêmica / sabotagem por acesso a áreas críticas
Provedores de serviço de telecomunicações e de acesso à RSFN	Riscos de disponibilidade de serviços críticos e interceptação de dados telemáticos

A criticidade dos prestadores pode ser graduada da seguinte forma:

- CRITICIDADE BAIXA – *Suporte sem acesso a ativos críticos*

Critério	**Condição**
Dados	Apenas dados públicos ou administrativos
Sistemas	Nenhum ou somente leitura
Infraestrutura	Não hospeda, não opera
Credenciais	Não recebe contas privilegiadas

Critério	Condição
Continuidade	Não afeta serviços essenciais

Exemplos: design gráfico, limpeza, eventos, consultorias conceituais.

- CRITICIDADE MÉDIA – *Acesso operacional limitado*

Critério	Condição
Dados	Dados internos, mas não sensíveis
Sistemas	Acesso operacional restrito
Infraestrutura	Não hospeda produção
Credenciais	Sem privilégio
Continuidade	Impacto local e reversível

Exemplos: service desk N1, treinamento, BI sem dados pessoais, consultoria técnica.

- CRITICIDADE ALTA – *Acesso direto a dados sensíveis ou sistemas críticos*

Critério	Condição
Dados	Dados pessoais, financeiros, estratégicos
Sistemas	Opera sistemas de negócio
Infraestrutura	Opera produção
Credenciais	Pode receber acessos elevados
Continuidade	Pode interromper serviços críticos

Exemplos: fábricas de software, RH, contabilidade, CRM, ERP, datacenter, colocation.

- CRITICIDADE CRÍTICA – *Herdeiro direto do risco cibernético institucional*

Critério	Condição
Hospeda sistemas/dados	Sim
Opera identidade, redes ou segurança	Sim
Detém chaves, logs, backups	Sim
Processa dados sensíveis em escala	Sim
Impacto sistêmico	Sim

Exemplos: cloud, IAM, SOC, MSSP, backup, DR, AD as a Service, core banking, data lake.

Matriz de decisão:

Pergunta	Sim
Hospeda dados ou sistemas da empresa?	🔴 CRÍTICO
Opera identidade, redes, segurança?	🔴 CRÍTICO

Pergunta	Sim
Processa dados pessoais/sigilosos?	🟠 ALTO
Tem acesso privilegiado?	🟠 ALTO
Pode parar serviço essencial?	🟠 ALTO
Apenas suporte administrativo?	🟢 BAIXO

Perguntas de base que estamos preparando para avaliação de terceiros que seriam interessantes de serem respondidas pelo modelo (questionário em minuta ainda):

Segurança da Informação:

1. O prestador de serviço terá acesso a informações sensíveis (dados pessoais, informações sigilosas)?
2. O serviço a ser prestado suporta algum processo crítico do Banco ou envolve acesso a sistemas principais de TI?
3. Haverá colaboradores/mão de obra alocada no BNDES com acesso a ativos de TI do Banco? Os ativos de TI acessados são classificados como críticos para segurança da informação?
4. A contratação envolve acesso administrativo a recursos de TI do Banco?
5. A contratação envolve o acesso físico de colaboradores a instalações do Banco? Há acesso a áreas com ativos críticos de TI (CPD, Shafts, salas de telecom)?
6. O prestador de serviço pretende subcontratar os serviços?
7. Haverá previsão contratual de direito de auditoria por parte do Banco?
8. Há algum processo formalmente estabelecido para desativação do prestador de serviço e de garantia de exclusão segura de dados?
9. Haverá previsão de apólice de seguro de responsabilidade civil pelo prestador de serviço para mitigação de riscos para o Banco?

Lei Geral de Proteção de Dados:

1. Haverá compartilhamento de dados pessoais da contratante com o prestador de serviço?
2. Haverá subcontratação que envolva a transferência de dados pessoais do terceiro para o subcontratado?